

Stoquify Agent Runtime Phase 2A Governance Evidence Capture Execution Report

Date: 2026-07-25

Decision: Repository implementation complete; external capture blocked pending an authoritative identity/governance endpoint

Local database identities accepted: No

Internal activation: Not attempted and not authorized

Phase 3: Not authorized

Executive Result

Stoquify now has a provider-neutral, fail-closed governance evidence collector for the Phase 2A controlled-pilot release boundary.

The collector captures real product approval, independent security approval, and six-responsibility owner coverage from a separately authenticated external authority. It binds the attestation to the exact inactive `PILOT_CERTIFIED` package, release version, commit, artifact, manifest, and evidence bundle.

It expressly refuses to derive release evidence from local Prisma approval records, owner records, E2E users, seed identities, fixtures, tests, or demos.

The implementation does not activate an agent and cannot update any field outside `governance`, `approvals`, and `owners`.

Implemented Artifacts

- `scripts/agent-governance-evidence-capture.js`
- `scripts/__tests__/agent-governance-evidence-capture.test.js`
- `docs/agents-runtime/STOQUIFY_AGENT_GOVERNANCE_EVIDENCE_CAPTURE_RUNBOOK_2026-07-25.md`
- `docs/agents-runtime/STOQUIFY_AGENT_RUNTIME_OPERATIONAL_RELEASE_EVIDENCE_2026-07-25.json`
- `scripts/agent-operational-release-gate.js`
- `scripts/__tests__/agent-operational-release-gate.test.js`
- `scripts/agent-phase2a-command-gate.js`
- `.env.example`
- `package.json`

Security and Integrity Controls

Authority and authentication

- Query-free HTTPS is mandatory outside local development.
- Embedded URL credentials, query strings, and fragments are rejected.
- A managed bearer value of at least 32 characters is required.
- An ephemeral invalid value is sent first and must receive `401`.
- Responses are capped at 150 KB.

- The bearer value, authorization header, and raw response are never retained.

Identity assurance

Approvers and owners must use `directory://` or `identity://` references.

The collector rejects identities containing:

- `e2e`
- `test`
- `seed`
- `fixture`
- `demo`

Product and security approvers must be distinct. Every owner responsibility must have distinct primary and backup identities.

Release binding

The capture is bound to:

- package ID;
- release version;
- commit SHA;
- artifact digest;
- manifest hash;
- evidence-bundle hash.

The apply path compares every value with the frozen operational register and refuses any drift.

Temporal controls

- The authority attestation must be no older than 24 hours.
- Approval decisions must be in the past and unexpired.
- Owner acceptance must be in the past.
- Every owner coverage window must be current.

Mutation boundary

The updater may replace only:

- `governance` ;
- `approvals` ;
- `owners` .

It preserves release, CI, scheduler, alerting, credential rotation, declared status, and activation. Any requested, authorized, or recorded activation value blocks the update.

Commands Added

```
npm run agent:governance:evidence:report
npm run agent:governance:evidence:gate
npm run agent:governance:evidence:apply
```

Operational Gate Hardening

The operational release register now contains an independently evaluated `governance` section with:

- source authority reference;
- attestation reference and digest;
- capture SHA-256;
- invalid-auth reference;
- attestation timestamp;
- frozen release binding.

The gate independently validates all of those fields, enforces 24-hour freshness, and compares the governance binding with the release before evaluating approvals and owner coverage.

The current register remains correctly `BLOCKED` with 146 external evidence requirements and always reports:

```
activationAuthorized: false
```

Focused Verification

Verification	Result
Governance collector tests	9 passed
Operational gate tests	18 passed
Alert collector tests	9 passed
Reconciler collector tests	8 passed
Combined evidence suites	4 suites, 44 tests passed
Focused open-handle detection	Passed across all four evidence suites
Complete Jest	473 suites and 2,852 tests passed; 3 suites and 15 tests skipped; intermittent forced-worker-exit warning observed after completion
Focused evidence suites with <code>--detectOpenHandles</code>	7 suites and 73 tests passed cleanly; no open handle identified
Phase 2A static ratchet	Passed
Operational release report	<code>BLOCKED</code> , 146 blockers, activation false
Real governance collector preflight	Failed closed on <code>GOVERNANCE_EVIDENCE_URL_MISSING</code>
Local database identities accepted	No

Verification	Result
Secret values printed	No

External Authority Contract

The complete configuration, response schema, identity rules, capture procedure, and failure modes are defined in:

`docs/agents-runtime/STOQUIFY_AGENT_GOVERNANCE_EVIDENCE_CAPTURE_RUNBOOK_2026-07-25.md`

The authority must be backed by real organizational identity and approval records. A local database export is not an acceptable substitute.

Remaining External Work

This implementation closes the repository ingestion and validation gap. It does not create the real approval or ownership decisions.

Completion still requires:

- an independently administered authority endpoint;
- a managed evidence-endpoint secret;
- the frozen release identity;
- one real product approver;
- one distinct real security approver;
- real primary and backup identities for all six responsibilities;
- current runbook acceptance and coverage windows;
- immutable attestation, approval, and escalation references.

After those prerequisites exist, run:

```
npm run agent:governance:evidence:apply
npm run agent:operational-release:gate
```

The release can advance only to independent review. Activation remains a separate protected ceremony, and Phase 3 remains unauthorized.